
**CONCEPTO
ARQUITECTURA EMPRESARIAL
ONBOARDING DE TARJETAHABIENTES PREPAGO
CREDIBANCO
VERSIÓN 1.0**

HISTORIA DE REVISIONES

Fecha	Versión	Descripción	Autor
30/04/2026	1.0	Versión Inicial	Javier Ricardo Agudelo

TABLA DE CONTENIDO

HISTORIA DE REVISIONES	2
TABLA DE CONTENIDO	3
GUÍA DE USO	4
NECESIDAD.....	5
PREMISAS DEL CONCEPTO	6
LINEAMIENTOS	7
RESTRICCIONES	8
ARQUITECTURA PROPUESTA	9
Diagrama de Arquitectura.....	10
Descripción de componentes	11
Descripción del proceso.....	12
Controles de seguridad propuestos.....	13
Riesgos identificados	14
Aplicaciones y/o soluciones afectadas	15
ANEXOS.....	16

GUÍA DE USO

El presente documento detalla el concepto del equipo de arquitectura empresarial generado para la necesidad expuesta por el negocio. Se identifica la necesidad, premisas, lineamientos, restricciones y se detalla la arquitectura propuesta.

A su vez, contiene el detalle de los elementos evaluados y el análisis a alto nivel de los posibles componentes involucrados dentro de Credibanco.

Cómo diligenciar este documento:

- *No se deben eliminar las anotaciones al inicio de cada sección con información de lo que debe contener cada punto. Estas notas sirven para ayudar a determinar la información a rellenar y para ayudar a las personas que revisan el documento a saber que debe estar cumplimentado en cada apartado.*
- *No se deben eliminar puntos del índice o capítulos del documento. Si algún punto no aplica se pondrá el comentario "NO APLICA".*
- *No olvide actualizar la fecha y la versión del documento en el encabezado, y el nombre del archivo en el pie de página.*
- *Tenga la precaución de revisar todos los encabezados y pies de página del documento para confirmar que la información que figura en los mismos está correctamente actualizada, ya que hay encabezados y pies de página para diferentes secciones del documento, y para páginas pares e impares.*

NECESIDAD

El presente concepto se enfoca en definir la arquitectura propuesta para el flujo de onboarding de tarjetahabientes prepago nominados, cuyo objetivo es permitir que un tarjetahabiente cree sus credenciales de acceso al Portal Tarjetahabiente de forma segura, automática y sin intervención manual de la entidad emisora ni de Credibanco.

La necesidad surge a partir de la creación exitosa de una tarjeta prepago nominada, ya sea mediante archivo batch o API. Una vez creada la tarjeta, el sistema debe habilitar un mecanismo controlado para que el tarjetahabiente pueda realizar su pre-registro, validar su identidad, confirmar un segundo factor mediante OTP, definir su contraseña y acceder posteriormente al portal.

El flujo debe garantizar que únicamente el titular legítimo asociado a la tarjeta pueda completar el proceso de enrolamiento.

Las necesidades principales son:

- Permitir el pre-registro automático del tarjetahabiente después de la creación exitosa de una tarjeta prepago nominada.
- Generar un código único de pre-registro asociado a la tarjeta y al correo electrónico registrado.
- Validar la identidad del tarjetahabiente mediante el número de documento.
- Implementar un segundo factor de validación mediante OTP.
- Permitir la asignación segura de contraseña.
- Crear el usuario en el SSO bajo el Realm CARDHOLDER.
- Habilitar el primer acceso autenticado al Portal Tarjetahabiente.
- Registrar auditoría completa del proceso.
- Evitar exposición de datos sensibles de tarjeta como PAN, CVV2 o PIN durante el onboarding.

PREMISAS DEL CONCEPTO

Esta sección presenta las premisas que rigen la arquitectura propuesta.

- El onboarding aplica únicamente para tarjetas prepago nominadas, es decir, tarjetas que cuentan previamente con información del tarjetahabiente.
- La creación de la tarjeta puede originarse desde un proceso batch o desde una API.
- El correo electrónico del tarjetahabiente se recibe como parte de la información de creación de la tarjeta.
- El código de pre-registro será generado automáticamente después de la creación exitosa de la tarjeta.
- El código de pre-registro será único, criptográficamente seguro, de un solo uso y tendrá una vigencia máxima de 30 días.
- El portal de pre-registro será una aplicación independiente del Portal Tarjetahabiente autenticado.
- El backend de pre-registro será responsable de validar el código, la identidad, el OTP y la sesión temporal de registro.
- El número de documento será utilizado como username del tarjetahabiente en el Realm CARDHOLDER.
- El sistema de identidad será el SSO definido para la plataforma Prepago.
- El OTP será enviado al correo electrónico registrado del tarjetahabiente.
- El OTP no se almacenará en texto claro; se almacenará únicamente como hash.
- La contraseña definida por el tarjetahabiente será transmitida exclusivamente sobre TLS 1.3 y almacenada como hash seguro.
- El Portal de Pre-Registro no deberá capturar, consultar, almacenar ni exponer PAN, CVV2 o PIN.
- Todo el flujo deberá generar trazabilidad y auditoría con timestamp, IP, resultado y correlationId cuando aplique.

LINEAMIENTOS

Esta sección presenta los lineamientos que rigen la arquitectura propuesta.

- Se deberá aplicar el principio de mínima exposición de datos durante todo el proceso.
- El Portal de Pre-Registro no deberá manejar datos sensibles de tarjeta.
- El código de pre-registro deberá ser un UUID criptográfico o token equivalente con entropía suficiente.
- El código de pre-registro deberá estar asociado a una tarjeta específica, un correo electrónico y un estado controlado.
- El código de pre-registro deberá invalidarse después de su uso exitoso, expiración o superación de intentos permitidos.
- La validación de identidad deberá realizarse comparando el número de documento ingresado contra el documento asociado a la tarjeta.
- Se deberá limitar el número de intentos fallidos de validación de identidad a máximo 3.
- El OTP deberá tener una vigencia máxima de 5 minutos.
- Se deberá limitar el número de intentos fallidos de validación OTP a máximo 3.
- La sesión temporal posterior a la validación del OTP deberá tener un TTL máximo de 10 minutos.
- La sesión temporal solo deberá permitir la asignación de contraseña y creación de cuenta.
- La contraseña deberá cumplir política mínima de complejidad: mínimo 8 caracteres, una mayúscula, un número y un carácter especial.
- La contraseña deberá almacenarse usando algoritmos de hash robustos como bcrypt o argon2.
- Todos los endpoints deberán contar con rate limiting.
- El formulario de validación de cédula deberá contar con CAPTCHA para mitigar ataques automatizados.
- Todas las comunicaciones deberán realizarse sobre canales cifrados.
- Se deberá registrar auditoría completa del flujo sin incluir datos sensibles.
- El usuario creado en el SSO deberá quedar asociado a la entidad, tarjeta y atributos mínimos requeridos para operar en el Portal Tarjetahabiente.

RESTRICCIONES

Esta sección presenta las restricciones que rigen la arquitectura propuesta.

- El flujo depende de que la tarjeta prepago nominada haya sido creada exitosamente.
- El proceso depende de que el correo electrónico del tarjetahabiente sea recibido y almacenado correctamente durante la creación de la tarjeta.
- Si el correo electrónico es incorrecto, el tarjetahabiente no podrá completar el pre-registro sin intervención de la entidad emisora.
- El código de pre-registro tendrá una vigencia máxima de 30 días; después de ese tiempo deberá generarse un nuevo proceso.
- El código de pre-registro será de un solo uso.
- Al superar 3 intentos fallidos de validación de documento, el código se invalidará permanentemente.
- Al superar 3 intentos fallidos de validación OTP, la sesión o el proceso deberá invalidarse.
- El flujo no contempla modificación de datos personales del tarjetahabiente.
- El flujo no permite creación de usuarios para tarjetas innominadas.
- El Portal de Pre-Registro no deberá exponer funcionalidades transaccionales.
- El Portal de Pre-Registro no deberá permitir consulta de saldo, movimientos, bloqueo/desbloqueo ni activación de PIN.
- La creación del usuario depende de la disponibilidad del SSO y del Realm CARDHOLDER.
- El envío de correo depende de la disponibilidad del canal de notificación definido.
- El OTP será enviado al correo registrado; si el correo no está disponible, el proceso no podrá completarse automáticamente.

ARQUITECTURA PROPUESTA

La arquitectura propuesta define un flujo de pre-registro seguro para tarjetahabientes prepago nominados. El proceso inicia cuando el sistema de creación de tarjetas confirma la creación exitosa de una tarjeta nominada. A partir de este evento, se genera un código de pre-registro asociado a la tarjeta, al documento del tarjetahabiente y al correo electrónico registrado.

El tarjetahabiente recibe un correo con una URL de pre-registro. Al ingresar, el Portal de Pre-Registro solicita el número de documento y lo envía al backend para validación. Si el documento coincide con el tarjetahabiente asociado a la tarjeta, el sistema genera un OTP de 6 dígitos, lo almacena como hash y lo envía al correo registrado.

Una vez el tarjetahabiente valida el OTP, el sistema habilita una sesión temporal de registro con TTL de 10 minutos. Durante esta sesión, el usuario solo puede asignar su contraseña. El backend valida la política de contraseña, crea el usuario en el SSO bajo el Realm CARDHOLDER y marca el pre-registro como completado.

Finalmente, el tarjetahabiente puede acceder al Portal Tarjetahabiente utilizando su número de documento y la contraseña creada.

Diagrama de Arquitectura

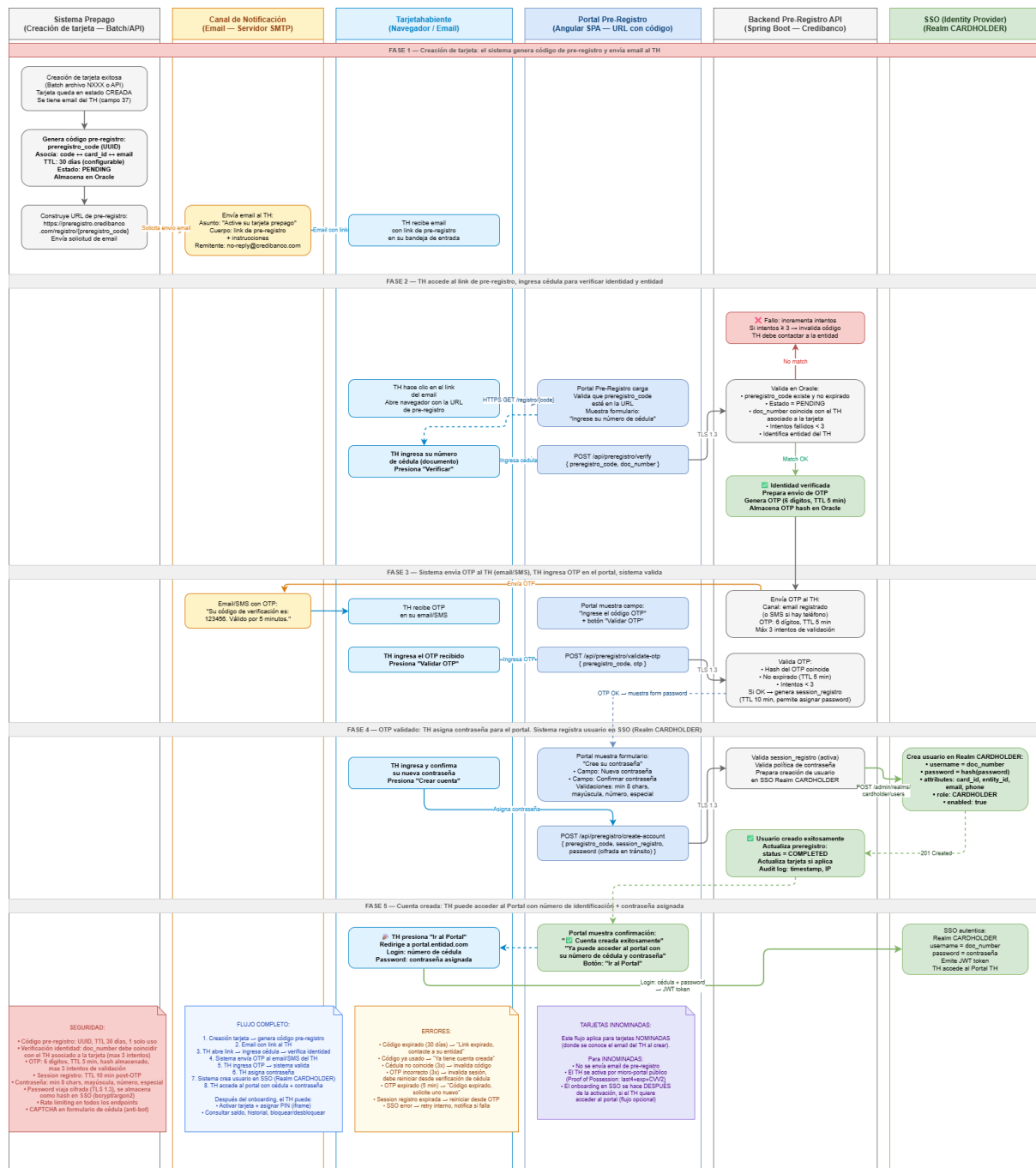


Diagrama 1. – Diagrama de Arquitectura

Descripción de componentes

<Se debe explicar cada componente del diagrama con el objetivo de brindar mayor claridad al lector.>

<Autores: Arquitecto >

Identificador	Componente	Descripción
CSA-001	Sistema Prepago	Sistema responsable de ejecutar la creación de tarjetas prepago nominadas mediante archivo batch o API. Al finalizar la creación exitosa, activa el flujo de pre-registro.
CSA-002	Módulo de generación de pre-registro	Componente encargado de generar el código único de pre-registro, asociarlo a la tarjeta, documento, correo electrónico y controlar su estado, TTL e intentos.
CSA-003	Canal de Notificación	Servicio de correo electrónico encargado de enviar al tarjetahabiente la URL de pre-registro y posteriormente el OTP.
CSA-004	Tarjetahabiente	Usuario titular de la tarjeta prepago nominada que recibe el correo, accede al portal, valida su identidad, confirma OTP y define contraseña.
CSA-005	Portal Pre-Registro	Aplicación web pública donde el tarjetahabiente realiza la validación de documento, OTP y asignación de contraseña. No maneja PAN, CVV2 ni PIN.
CSA-006	Backend Pre-Registro API	Servicio backend que valida el código de pre-registro, documento, OTP, sesión temporal y orquesta la creación del usuario en el SSO.
CSA-007	Base de datos operacional	Repositorio donde se almacena el estado del pre-registro, intentos, TTL, hash del OTP, auditoría y trazabilidad del proceso.
CSA-008	SSO Identity Provider	Sistema de identidad encargado de crear y autenticar usuarios bajo el Realm CARDHOLDER.
CSA-009	Realm CARDHOLDER	Realm lógico donde se registran los usuarios tarjetahabientes, usando el número de documento como username.
CSA-010	Portal Tarjetahabiente	Portal autenticado al que el tarjetahabiente accede después de completar el onboarding.

Tabla 1. – Listado Responsabilidades de Componentes

Descripción del proceso

Fase 1. Creación de tarjeta y generación de pre-registro

Cuando se crea exitosamente una tarjeta prepago nominada, el Sistema Prepago genera un código de pre-registro único. Este código se asocia a la tarjeta, al correo electrónico registrado, al número de documento del tarjetahabiente y a un estado inicial activo.

El código tendrá las siguientes características:

- UUID criptográfico.
- TTL de 30 días.
- Uso único.
- Estado controlado: pendiente, completado, expirado o invalidado.
- Asociación directa a una tarjeta específica.
- Asociación al correo electrónico registrado.

Posteriormente, el sistema construye una URL de pre-registro y solicita el envío del correo al tarjetahabiente.

Fase 2. Envío de correo al tarjetahabiente

El canal de notificación envía un correo electrónico al tarjetahabiente con la URL de pre-registro y las instrucciones para activar su cuenta.

El correo no debe incluir datos sensibles de tarjeta. Solo debe contener:

- Mensaje de activación.
- URL de pre-registro.
- Instrucciones generales.
- Vigencia del enlace.
- Recomendaciones de seguridad.

Fase 3. Validación del código y verificación de identidad

El tarjetahabiente accede a la URL recibida. El Portal de Pre-Registro carga el código incluido en la URL y solicita al backend validar que:

- El código exista.
- No haya expirado.
- No haya sido usado previamente.
- No esté invalidado.
- Esté asociado a una tarjeta válida.

Luego, el portal solicita el número de documento del tarjetahabiente. El backend compara el documento ingresado contra el documento asociado a la tarjeta y al código de pre-registro.

Si el documento no coincide, el sistema incrementa el contador de intentos fallidos. Al superar 3 intentos, el código se invalida permanentemente y el tarjetahabiente deberá contactar a su entidad emisora.

Fase 4. Generación y envío de OTP

Cuando la identidad es validada correctamente, el backend genera un OTP de 6 dígitos con TTL de 5 minutos. El OTP se almacena únicamente como hash y se envía al correo electrónico registrado.

El OTP debe cumplir con los siguientes controles:

- Vigencia máxima de 5 minutos.
- Máximo 3 intentos de validación.
- Almacenamiento como hash.
- No registro en logs.
- No exposición en respuestas de API.
- Asociación al código de pre-registro y a la sesión de validación.

Fase 5. Validación de OTP y creación de sesión temporal

El tarjetahabiente ingresa el OTP en el Portal de Pre-Registro. El backend valida que:

- El OTP corresponda al hash almacenado.
- El OTP no haya expirado.
- El número de intentos no haya sido superado.
- El código de pre-registro continúe activo.

Si el OTP es correcto, el backend genera una sesión temporal de registro con TTL de 10 minutos. Esta sesión solo permite la operación de asignación de contraseña.

Fase 6. Asignación de contraseña

El portal presenta al tarjetahabiente el formulario para crear su contraseña. La contraseña debe cumplir la política mínima definida:

- Mínimo 8 caracteres.
- Al menos una letra mayúscula.
- Al menos un número.
- Al menos un carácter especial.

La contraseña se transmite sobre TLS 1.3 hacia el backend. El backend no debe registrar la contraseña en logs ni almacenarla en texto claro.

Fase 7. Creación del usuario en SSO

El Backend Pre-Registro API invoca el SSO para crear el usuario en el Realm CARDHOLDER.

El usuario se crea con:

- Username: número de documento del tarjetahabiente.
- Password: contraseña asignada por el usuario.
- Atributos de tarjeta.
- Atributos de entidad emisora.
- Correo electrónico registrado.
- Estado habilitado.

Una vez creado el usuario, el backend actualiza el estado del pre-registro a completado, invalida el código de pre-registro y registra la auditoría del proceso.

Fase 8. Primer acceso al Portal Tarjetahabiente

El tarjetahabiente accede al Portal Tarjetahabiente usando su número de documento y contraseña. El SSO autentica al usuario y emite el token JWT correspondiente.

A partir de este momento, el tarjetahabiente puede acceder a las funcionalidades habilitadas del portal, como:

- Consulta de saldo.
- Consulta de movimientos.
- Bloqueo o desbloqueo de tarjeta.
- Activación de tarjeta.
- Asignación de PIN mediante iframe seguro, cuando aplique.

Controles de seguridad propuestos

Control	Descripción
Código de pre-registro seguro	UUID criptográfico, de un solo uso, con TTL de 30 días.
Asociación del código	El código se asocia a tarjeta, documento, correo electrónico y entidad emisora.
Validación de identidad	El documento ingresado debe coincidir con el documento asociado a la tarjeta.
Límite de intentos	Máximo 3 intentos fallidos para documento y OTP.

Invalidación automática	El código se invalida por expiración, uso exitoso o exceso de intentos.
OTP seguro	OTP de 6 dígitos, TTL de 5 minutos, almacenado como hash.
Sesión temporal	TTL de 10 minutos, únicamente para asignación de contraseña.
Política de contraseña	Mínimo 8 caracteres, mayúscula, número y carácter especial.
Hash de contraseña	Almacenamiento mediante bcrypt o argon2.
Cifrado en tránsito	Uso de TLS 1.3 en las comunicaciones del portal y backend.
Rate limiting	Aplicado sobre todos los endpoints del flujo.
CAPTCHA	Aplicado en formulario de validación de documento.
Auditoría	Registro de eventos con timestamp, IP, resultado y trazabilidad.
No exposición de CHD	El Portal de Pre-Registro no maneja PAN, CVV2 ni PIN.

Riesgos identificados

Riesgo	Mitigación propuesta
Uso indebido del enlace de pre-registro	Código único, de un solo uso, con TTL e invalidación por intentos.
Ataques de fuerza bruta sobre documento	CAPTCHA, rate limiting y máximo 3 intentos.
Compromiso del correo electrónico del tarjetahabiente	Validación adicional mediante documento y OTP.
Reutilización del código de pre-registro	Invalidación automática después de uso exitoso.
Ataques automatizados contra el portal	CAPTCHA, rate limiting y auditoría.
Exposición de OTP	OTP almacenado como hash y no registrado en logs.
Creación de cuenta por persona no autorizada	Validación combinada de enlace, documento y OTP.
Contraseña débil	Política mínima de complejidad y almacenamiento con hash robusto.
Falta de trazabilidad	Auditoría por cada paso del proceso.
Exposición de datos sensibles de tarjeta	El flujo no consulta ni renderiza PAN, CVV2 ni PIN.

Aplicaciones y/o soluciones afectadas

Aplicación / solución	Impacto
Sistema Prepago	Debe generar el evento o acción de pre-registro después de la creación exitosa de la tarjeta.
Orquestador de creación de tarjetas	Debe proveer la información necesaria para asociar tarjeta, documento, correo y entidad.
Canal de notificación	Debe enviar correos de pre-registro y OTP.
Portal Pre-Registro	Nueva interfaz pública para validación de identidad, OTP y asignación de contraseña.
Backend Pre-Registro API	Nuevo servicio o capacidad backend para gestionar el flujo de enrolamiento.
Base de datos operacional	Persistencia de códigos, estados, intentos, hash de OTP y auditoría.
SSO Identity Provider	Creación y autenticación de usuarios bajo el Realm CARDHOLDER.
Realm CARDHOLDER	Realm donde residirán los usuarios tarjetahabientes.
Portal Tarjetahabiente	Portal destino después del registro exitoso.
Plataforma de auditoría/logs	Registro de eventos técnicos y de seguridad del proceso.

ANEXOS

<Se incluye documentos de referencia que hacen parte del diseño de Arquitectura >

<Autores: Arquitecto>

NOMBRE	OBSERVACIONES
	<Link de referencia del anexo>

Tabla 2.